Pentest local

Resultados y hallazgos — Ronda 3

Equipo SOS Clinic

22 de octubre de 2026

1 Resumen

Métrica	Resultado	Evidencia
Casos ejecutados	**62 PASS, 2 FAIL, 3 WARN, 0 SKIP**	`fase2-pentest.csv`
Matriz de autorización	8 roles × 11 endpoints, sin desviaciones	M-01 a M-11
JWT y sin token	401 en todos los intentos	A-01 a A-09, A-17, A-18
2FA y login	Challenge de un solo uso y bloqueo tras 5 fallos	A-10 a A-14
XSS almacenado	0 diálogos y 0 etiquetas inyectadas	Evidencias PNG

Cuadro 1: Resumen del pentest local.

2 Resultados por área

Área	Comprobación	Resultado
JWT	Firma distinta, `alg=none`, payload manipulado	**PASS**
Sin token	Gateway y 5 puertos directos	**PASS**
Autorización	11 endpoints con 8 roles	**PASS**
CORS	Origen permitido y `evil.local`	**PASS**
Cabeceras	Gateway y frontend	**PASS**
CSP	`unsafe-inline`	**WARN**
Traversal / Actuator	`/.env`, `.git/config`, `/actuator/env`	**PASS**
Datos	Mass assignment, SQLi, JSON, referencias	**PASS**
IDOR	Episodios, pacientes e historias	**PASS** por rol
PDF clínico	Recepción y lista de espera	**WARN**
2FA / login	Un solo uso, bloqueo, enumeración	**PASS**
Validación	Campos obligatorios vacíos	**FAIL**

Cuadro 2: Resultado por área del pentest.

3 XSS almacenado

El escapado HTML funciona y H-07 sigue remediado. Evidencias: `evidencias/xss-pacientes-r3.png`, `evidencias/xss-lista-espera-r3.png` y `evidencias/xss-seguimiento-r3.png`.

Página	`window.__xss`	`<img>` inyectadas	Payload como texto	Diálogos
`pacientes.html`	0	0	Sí	Ninguno
`lista-espera.html`	0	0	Sí	Ninguno
`seguimiento.html`	0	0	Sí	Ninguno

Cuadro 3: Resultado de la prueba de XSS con navegador real.

4 Hallazgos nuevos

F-01. Validación de campos devuelve 500 (Media)

`ms-seguridad` no maneja `MethodArgumentNotValidException`. Un cuerpo sin campos obligatorios en `/auth/login` o `/auth/recuperar-clave` responde 500 en vez de 400. Evidencia: A-15 y A-16. **Mejora:** agregar el manejador y una prueba de controller.

F-02. PDF clínico para roles no clínicos (Media-baja)

`recepcionista` y `lista_espera` descargan la historia clínica completa de cualquier episodio (200). Evidencia: I-04-recepcion e I-04-listas. **Mejora:** restringir el PDF a administrador/médico o validar la asignación del episodio.

F-03. CSP con `unsafe-inline` (Baja, residual H-18)

Permite scripts y estilos inline. No se encontró XSS explotable, pero reduce la defensa en profundidad. **Mejora:** mover scripts y `onclick` a archivos y endurecer la CSP.

F-04. IDOR horizontal por diseño (Informativo, residual H-09)

Cualquier rol clínico lee cualquier paciente o episodio; no hay propiedad por episodio. Es el residual aceptado en la ronda 2.

F-05. Clave Grafana en el historial (Informativo)

Tres coincidencias históricas en un archivo ya eliminado. Rotar si fue real.

F-06. Timeout SMTP del PDF (Informativo)

Observado en fase 1; el reintento funciona. Se recomienda envío asíncrono.

5 Re-verificación de la ronda 2

ID	Estado	Evidencia
H-01	Remediado	A-01 a A-03
H-02	Remediado	A-04 a A-07
H-03	Remediado	A-17, A-18
H-04	Remediado	M-01 a M-03
H-05	Remediado	Gitleaks árbol 0; `.env` ignorado
H-06	Remediado	Trivy 0 vulnerabilidades
H-07	Remediado	XSS: 0 diálogos, 0 etiquetas
H-08	Remediado	D-01, D-02
H-09	Residual aceptado	I-01 a I-04

H-10	Remediado	A-08, M-10
H-11	Remediado	C-01 a C-03
H-12	Remediado	A-10, A-11
H-13	Remediado en árbol	Gitleaks árbol 0; F-05 histórico
H-14	Remediado	Trivy 0 vulnerabilidades
H-15	Remediado	A-14
H-16	Remediado	E-01 a E-04
H-17	Remediado	A-12, A-13
H-18	Parcial	C-04 a C-07
H-19	Remediado	Compose en loopback; secretos por `.env`
H-20	Remediado	`show-sql=false`; logs sin secretos reales
H-21	Remediado	V-01, V-02
H-22	Parcial	D-05 a D-07; F-01 es otra validación
H-23	Remediado	Matriz y puertos directos
H-24	Remediado	M-09
H-25	Documentado	Gitleaks árbol 0; historial Grafana

6 Conclusión

No hay fallos críticos ni altos abiertos. Los dos hallazgos nuevos (F-01 y F-02) son acotados y corregibles en `main`; los residuales H-09/H-18 y el histórico F-05 ya estaban documentados. El plan priorizado está en `seguridad/resultados/plan-mejoras-main.md`.